Company: Apex Financial services (Simulated and fictional)

Audit type: Employee Access Management Review

Framework: NIST SP 800-53

Status: Completed but open (Remediation pending)

1. Executive Summary

The purpose of this audit was to review employee access permissions and identify potential security risks within a simulated company environment.

I reviewed 10 employee accounts across the IT, HR, Finance, and Sales departments. I then used Role-Based Access Control (RBAC) and the principle of least privilege to decide whether employees had the right access for their job responsibilities.

During the audit, I found three security findings involving unauthorized access, excessive administrative privileges, and incomplete employee offboarding.

These findings show why organizations need regular access reviews and clear procedures for managing employee permissions.

2. Audit Scope/Methods

The audit focused around employee account management, access permissions, and compliance with the company's access control policies.

To complete the audit, I:

1. Created an employee directory containing 10 fictional accounts.
2. Developed an RBAC matrix outlining approved permissions for each job role.
3. Compared simulated employee access assignments against the approved permissions.
4. Identified access violations and documented security findings.
5. Evaluated risks based on likelihood and potential impact.
6. Mapped findings to relevant NIST SP 800-53 security controls.
7. Developed recommendations to address the identified risks.

The assessment was limited to simulated records and did not involve testing a live identity management system.

3. Audit Results

The review results are listed below

Audit Metric	Result
Total Accounts Reviewed	10
Accounts Passed	7
Accounts Failed	3
Access Review Pass Rate	70%
Identified Findings	3

70% of accounts had permissions that matched their approved roles, while 30% of accounts had access-related issues requiring corrective action.

4. Security Findings/Risk Assessment

1: Excessive Administrative Privileges

Risk Level: High

Risk Score: 20

Emily Davis, an IT Support employee, had full administrative permissions even though her role required just limited access.

This violates the principle of least privilege.

Recommendation: Lower administrative permissions to the approved level and conduct regular privileged access reviews.

2: Unauthorized Financial Data Access

Risk Level: High

Risk Score: 15

David Wilson, a Sales Representative, had access to financial information that was not required for his position.

This creates a risk of sensitive financial information being accessed or exposed without the right authorization.

Recommendation: Remove unauthorized financial permissions and enforce access restrictions based on employee job roles.

3: Incomplete Employee Offboarding

Risk Level: Medium

Risk Score: 12

Chris Taylor, a former employee, still had Sales CRM permissions assigned to his disabled account.

Although the account was disabled, the remaining permissions indicate a mishap in the employee offboarding process.

Recommendation: Remove the remaining permissions, verify account deactivation, and establish an offboarding checklist.

Risk scores were calculated by using a 5x5 likelihood and impact assessment..

5. NIST Control Mapping

I mapped the audit findings to relevant NIST SP 800-53 controls to identify areas of improvement in the company's IAM practices.

Control Name	Related Finding
Account Management	Incomplete offboarding
Access Enforcement	Unauthorized financial access
Least Privilege	Excessive admin privileges
Identification and Authentication	Not assessed

Identification and Authentication was used for future audits because authentication settings were outside the audit scope.

6. Recommendations and Conclusion

Based on the audit results, I recommend that the organization strengthen its access management practices by implementing regular employee access reviews, enforcing least privilege, and improving its offboarding procedures.

The three identified findings remain open because remediation has been recommended but not implemented or verified.

This project allowed me to practice the process of conducting an IAM access review, identifying security weaknesses, assessing risks, and documenting findings using recognized security controls.

Through this simulated assessment, I gained a better understanding of how IAM and GRC practices work together to protect confidential info and reduce risk.